Canton 402

An agent-era corporate card on Canton. A business hands its AI agent a spending mandate, and the agent buys services on its own. It stays private, settles atomically, and can only spend within the rules.

THE PROBLEM

Agents are starting to spend money on data, compute, and other agents' services. Two things break the moment they do. You cannot hand an agent an open wallet: a buggy or prompt-injected agent should not be able to drain an account or pay a stranger. And business payments are not meant to be public, so a transparent chain that exposes every vendor, price, and volume is a non-starter for real treasury flows.

THE MANDATE IS A CONTRACT, NOT CONFIG

ACME issues its agent a spending card, written as a Daml contract:

- Per transaction `≤ 100`
- Per day `≤ 250`
- Vendors `an allow-list`
- Auditor `a named party`

The limits live on the ledger, so the agent's own code can never talk its way past them. A guardrail written as a Daml contract is enforced by the ledger itself.

HOW IT WORKS · ONE ATOMIC CHOICE

PayAndCall on a vendor's ServiceOffer does four things in a single Daml transaction. All four commit together or none do.

1. Check the agent's mandate (cap, daily total, allow-list)
2. Settle payment to the vendor, change back to the agent
3. Deliver the service entitlement
4. Write a hash-chained, tamper-evident receipt

There is never payment without delivery, and never a spend that breaks policy.

WHAT RUNS TODAY · ALL ON A REAL LEDGER

- **Acceptance suite** (`daml test`): two settled purchases with a chained receipt trail; three out-of-policy attempts rejected on-ledger.
- **Autonomous agent** over an HTTP 402 gateway: discovers services, gets 402, pays, receives the on-ledger receipt. No Canton SDK needed.
- **MCP server** exposes the same tools to any LLM client.
- **Live web dashboard** drives the gateway: watch the handshake, the settlement, and the receipt chain grow.

PRIVACY COMES FROM CANTON'S OWN MODEL

After two purchases, the same "which receipts can you see?" query returns a different answer to each party:

- Auditor `2` both receipts
- Each vendor `1` only its own
- Rival on the network `0` nothing

MAPS TO SUMPLUS PRODUCTS

`Mandate` is the Maria policy layer expressed in Daml. `ServiceOffer` is the Arsenal paid-skill model. The hash-chained `receipt` is the same verifiable-audit pattern Sumplus already runs on its EVM trading agent, here native to Daml.